

UNIVERSITÉ HASSAN 1^{er}
FACULTÉ DES SCIENCES ET TECHNIQUES

**Rapport d'incident SOC : Détection d'attaque
par force brute (Hydra) via Suricata et ELK
Stack – Lab du 06 mai 2026**

Réalisé par :

Meryem Jarti

Encadré par :

Pr. Chaimae Azroumahli

Année universitaire : 2025 – 2026

Table des matières

Table des figures :	3
Table des tableaux :	3
1. Résumé exécutif :	4
2. Infrastructure du lab :	4
3. Chronologie de l'incident (Timeline) :	5
3.1. Phase de préparation (avant 11:39) :	5
3.2. Attaque 1 - Force brute SSH : 11:39 UTC+1	6
3.3. Attaque 2 - Force brute HTTP POST : 12:29 UTC+1	8
4. Analyse du Dashboard Kibana – Visualisation SOC :	10
4.1. Visualisation 1 : Compteur global d'alertes (KPI)	10
4.2. Visualisation 2 : Évolution temporelle des alertes	11
4.3. Visualisation 3 : Top signatures déclenchées	12
4.4. Visualisation 4 : Top Sources IP (Pie chart)	13
4.5. Visualisation 5 : Types d'attaques (bar chart)	14
5. Analyse des logs Suricata – fast.log	15
6. Résumé des indicateurs de compromission (IoC) :	17
7. Recommandations de remédiation :	18
Conclusion :	19

Table des figures :

Figure 1 Topologie du laboratoire.....	4
Figure 2 Dashboard Kibana Baseline pré-attaque.....	6
Figure 3 Attaque 1 – Commande Hydra SSH (lancement)	7
Figure 4 Attaque 1 – Résultat Hydra SSH (credentials trouvés)	8
Figure 5 Commande Hydra HTTP POST (lancement).....	9
Figure 6 Résultat Hydra HTTP POST (credentials trouvés).....	10
Figure 7 KPI Kibana – Total des alertes (34)	11
Figure 8 Graphique temporel – Pic d'alertes concentré entre 12h19 et 12h30.....	12
Figure 9 Top signatures déclenchées.....	12
Figure 10 Diagramme circulaire – Top sources IP	13
Figure 11 Histogramme – Types d'attaques détectées	14
Figure 12 Top ports ciblés	15
Figure 13 Extrait du fichier fast.log de Suricata	16

Table des tableaux :

Tableau 1 Infrastructure du laboratoire.....	4
Tableau 2 Répartition des alertes par IP source	13
Tableau 3 Top des ports ciblés	14
Tableau 4 Indicateurs de compromission (IoC)	17

1. Résumé exécutif :

Dans le cadre d'un exercice de détection en environnement de laboratoire, une attaque par force brute ciblant les services SSH (port 22) et HTTP (port 80) a été détectée en temps réel par le système IDS Suricata, corrélé avec la plateforme SIEM ELK Stack.

L'origine de l'attaque est la machine Kali Linux 192.168.10.10, qui a utilisé l'outil Hydra v9.5 pour tester automatiquement des combinaisons de noms d'utilisateur et de mots de passe contre la cible 192.168.10.20, entre 11h39 et 12h30 UTC+1. Le SIEM Kibana a enregistré un total de 34 alertes sur la durée de l'exercice.

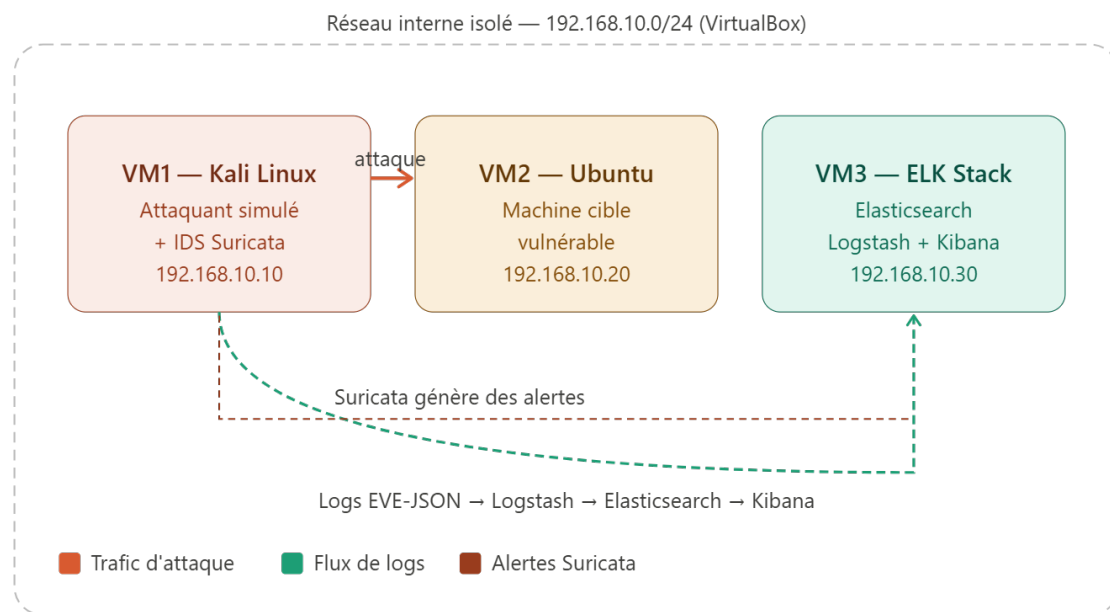


Figure 1 Topologie du laboratoire

L'analyse des signatures déclenchées, de l'IP source et des ports ciblés confirme sans ambiguïté une activité de type Credential Brute Force, correspondant à la phase 4 de la Cyber Kill Chain (Lockheed Martin) : Exploitation. Les deux accès ont été compromis avec succès : les credentials user:test (SSH) et admin:admin123 (HTTP) ont été trouvés par Hydra.

2. Infrastructure du lab :

Tableau 1 Infrastructure du laboratoire

Rôle	Hostname	IP
Attaquant	Kali Linux	192.168.10.10
Cible	Target (Ubuntu Server)	192.168.10.20
SIEM / IDS	ELK Stack + Suricata	192.168.10.30

Toutes les machines appartiennent au même réseau interne isolé 192.168.10.0/24. La topologie est un réseau plat sans segmentation, ce qui, dans un contexte réel, constituerait une faiblesse architecturale majeure : l'absence de VLAN et de pare-feu inter-zone permet à un attaquant d'atteindre tous les services directement depuis n'importe quelle machine du réseau.

3. Chronologie de l'incident (Timeline) :

3.1. Phase de préparation (avant 11:39) :

Avant le déclenchement de l'attaque, le dashboard Kibana affichait un compteur global en état de repos (N/A aucune alerte active). Le graphique temporel montrait une ligne plate sans aucun pic notable, confirmant l'état de calme du réseau.

Lecture analyste : Ce baseline pré-attaque est indispensable. Il représente l'état normal du système et permet de distinguer clairement toute activité anormale qui surviendrait par la suite. Sans baseline, il est impossible de savoir si un pic d'alertes est exceptionnel ou habituel. C'est le point de départ de toute analyse dans un SOC.

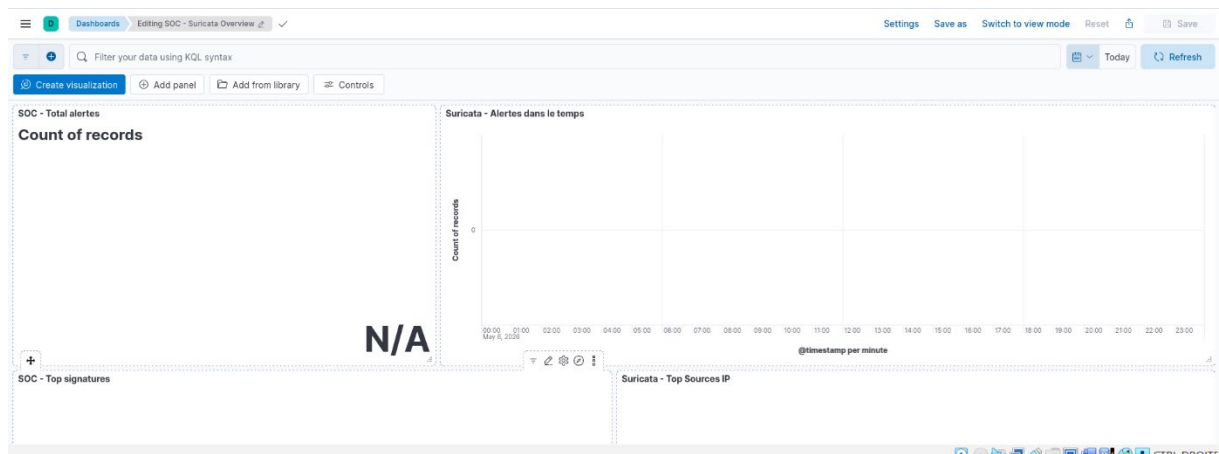


Figure 2 Dashboard Kibana Baseline pré-attaque

Durant cette phase de préparation, deux fichiers de mots de passe légers ont été créés sur la machine Kali, contenant respectivement 20 entrées pour SSH et 18 entrées pour HTTP, avec le bon mot de passe inclus à une position réaliste dans chaque liste. Un fichier de noms d'utilisateur a également été préparé (root, admin, user, ubuntu). Ces listes minimalistes permettent de simuler une attaque réaliste sans saturer les ressources du système.

3.2. Attaque 1 - Force brute SSH : 11:39 UTC+1

Commande exécutée :

```
hydra -L /tmp/users.txt -P /tmp/pass_ssh.txt ssh://192.168.10.20 -t 4 -V -f
```

```
(root@kali)-[~] Add from library Controls
# hydra -L /tmp/users.txt -P /tmp/pass_ssh.txt ssh://192.168.10.20 -t 4 -V -f
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-06 11:
39:22
[DATA] max 4 tasks per 1 server, overall 4 tasks, 80 login tries (l:4/p:20),
~20 tries per task
[DATA] attacking ssh://192.168.10.20:22/
[ATTEMPT] target 192.168.10.20 - login "root" - pass "123456" - 1 of 80 [chil
d 0] (0/0)
[ATTEMPT] target 192.168.10.20 - login "root" - pass "password" - 2 of 80 [ch
ild 1] (0/0)
[ATTEMPT] target 192.168.10.20 - login "root" - pass "admin" - 3 of 80 [child
 2] (0/0)
[ATTEMPT] target 192.168.10.20 - login "root" - pass "letmein" - 4 of 80 [chi
ld 3] (0/0)
[ATTEMPT] target 192.168.10.20 - login "root" - pass "root" - 5 of 80 [child
 1] (0/0)
[ATTEMPT] target 192.168.10.20 - login "root" - pass "toor" - 6 of 80 [child
 0] (0/0)
[ATTEMPT] target 192.168.10.20 - login "root" - pass "ubuntu" - 7 of 80 [chil
d 2] (0/0)
[ATTEMPT] target 192.168.10.20 - login "root" - pass "linux" - 8 of 80 [child
 3] (0/0)
```

Figure 3 Attaque 1 – Commande Hydra SSH (lancement)

Explication des options utilisées :

- -L : fichier contenant la liste des noms d'utilisateur à tester
- -P : fichier contenant la liste des mots de passe à tester
- -t 4 : limite à 4 tâches parallèles (au lieu de 16 par défaut) pour éviter de surcharger le système
- -V : mode verbeux — affiche chaque tentative en temps réel
- -f : arrête l'attaque dès le premier succès trouvé

Résultat :

- 80 combinaisons testées au total (4 utilisateurs × 20 mots de passe)
- Credentials trouvés à la tentative n°56 sur 80 :
Login : user
Mot de passe : test
- Durée de l'attaque : environ 40 secondes (11:39:22 → 11:40:02)

```
[ATTEMPT] target 192.168.10.20 - login "user" - pass "test1234" - 56 of 80 [c  
hild 0] (0/0)  
[22][ssh] host: 192.168.10.20 login: user password: test  
[STATUS] attack finished for 192.168.10.20 (valid pair found)  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-06 11:  
40:02
```

Figure 4 Attaque 1 – Résultat Hydra SSH (credentials trouvés)

Analyse : L'attaque SSH par force brute consiste à tester automatiquement une série de combinaisons identifiant/mot de passe jusqu'à en trouver une valide. Hydra a établi 4 connexions TCP parallèles vers le port 22 de la cible, en envoyant une tentative d'authentification SSH pour chaque combinaison. Chaque tentative échouée génère une connexion SYN visible dans les logs réseau, ce que Suricata détecte grâce à la règle configurée sur le port 22 (SID 1000002).

Impact SOC : La compromission d'un compte SSH donne à l'attaquant un accès shell complet sur la machine cible. Dans un contexte réel, cela représente une compromission totale du système : l'attaquant peut exécuter des commandes, lire et exfiltrer des fichiers, installer des logiciels malveillants, et se déplacer latéralement vers d'autres machines du réseau.

3.3. Attaque 2 - Force brute HTTP POST : 12:29 UTC+1

Contexte : La machine cible héberge une application web PHP avec un formulaire de connexion sur /login.php. Ce formulaire retourne le texte "Invalid credentials" en cas d'échec d'authentification, et "SUCCESS" en cas de succès. Cette réponse d'échec est utilisée par Hydra comme critère de détection automatique du résultat.

Commande exécutée :

```
hydra -l admin -P /tmp/pass_http.txt 192.168.10.20 http-post-form  
"/login.php:user=^USER^&pass=^PASS^:Invalid credentials" -t 4 -V -f
```



```
└─# hydra -l admin -P /tmp/pass_http.txt 192.168.10.20 http-post-form "/login
.php:user=^USER^&pass=^PASS^:Invalid credentials" -t 4 -V -f
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-06 12:
29:48
[DATA] max 4 tasks per 1 server, overall 4 tasks, 18 login tries (l:1/p:18),
~5 tries per task
[DATA] attacking http-post-form://192.168.10.20:80/login.php:user=^USER^&pass
=^PASS^:Invalid credentials
[ATTEMPT] target 192.168.10.20 - login "admin" - pass "admin" - 1 of 18 [chil
d 0] (0/0)
[ATTEMPT] target 192.168.10.20 - login "admin" - pass "password" - 2 of 18 [c
hild 1] (0/0)
[ATTEMPT] target 192.168.10.20 - login "admin" - pass "123456" - 3 of 18 [chi
ld 2] (0/0)
[ATTEMPT] target 192.168.10.20 - login "admin" - pass "admin123" - 4 of 18 [c
hild 3] (0/0)
[ATTEMPT] target 192.168.10.20 - login "admin" - pass "letmein" - 5 of 18 [ch
ild 1] (0/0)
[ATTEMPT] target 192.168.10.20 - login "admin" - pass "welcome" - 6 of 18 [ch
ild 0] (0/0)
[ATTEMPT] target 192.168.10.20 - login "admin" - pass "root" - 7 of 18 [child
 2] (0/0)
```

Figure 5 Commande Hydra HTTP POST (lancement)

Explication des options spécifiques à l'attaque HTTP :

- -l admin : un seul nom d'utilisateur ciblé (admin)
- http-post-form : module Hydra pour les formulaires HTTP en méthode POST
- /login.php:user=^USER^&pass=^PASS^ : URL du formulaire et structure du corps de la requête, avec ^USER^ et ^PASS^ remplacés automatiquement par les valeurs testées
- Invalid credentials : chaîne de texte présente dans la réponse en cas d'échec — Hydra s'en sert pour identifier les tentatives ratées

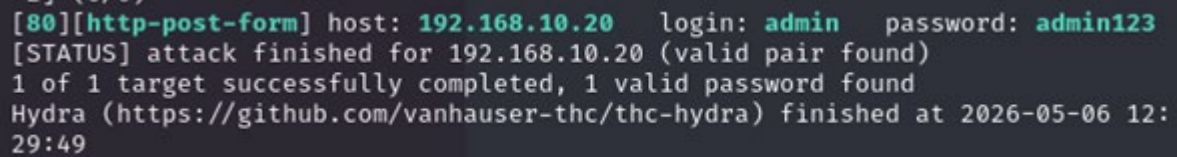
Résultat :

- 18 combinaisons testées au total (1 utilisateur × 18 mots de passe)
- Credentials trouvés à la tentative n°4 sur 18 :

Login : admin

Mot de passe : admin123

- Durée de l'attaque : moins d'1 seconde (12:29:48 → 12:29:49)

A terminal window with a dark background and light green text. The text shows the output of a Hydra attack. It starts with '[80][http-post-form] host: 192.168.10.20 login: admin password: admin123'. The next line is '[STATUS] attack finished for 192.168.10.20 (valid pair found)'. The following line is '1 of 1 target successfully completed, 1 valid password found'. The final line is 'Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-06 12:29:49'.

```
[80][http-post-form] host: 192.168.10.20 login: admin password: admin123
[STATUS] attack finished for 192.168.10.20 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-06 12:
29:49
```

Figure 6 Résultat Hydra HTTP POST (credentials trouvés)

Analyse : L'attaque HTTP POST par force brute consiste à envoyer des requêtes HTTP répétées vers le formulaire de connexion, en changeant le mot de passe à chaque tentative. Contrairement à SSH qui dispose de mécanismes natifs de protection, une application web PHP basique ne limite pas le nombre de tentatives de connexion, ce qui la rend très vulnérable à ce type d'attaque. Le mot de passe admin123 a été trouvé en seulement 4 essais, ce qui montre à quel point les mots de passe faibles et prévisibles représentent un risque critique.

Impact SOC : La compromission du compte administrateur de l'application web donne accès à l'interface d'administration. Dans un contexte réel, une application web compromise peut permettre à l'attaquant d'injecter du code malveillant, d'accéder à une base de données, ou d'utiliser le serveur comme point d'entrée pour des attaques vers d'autres systèmes internes.

4. Analyse du Dashboard Kibana – Visualisation SOC :

4.1. Visualisation 1 : Compteur global d'alertes (KPI)

Valeur observée : 34 alertes (fenêtre de la session d'exercice du 06 mai 2026)

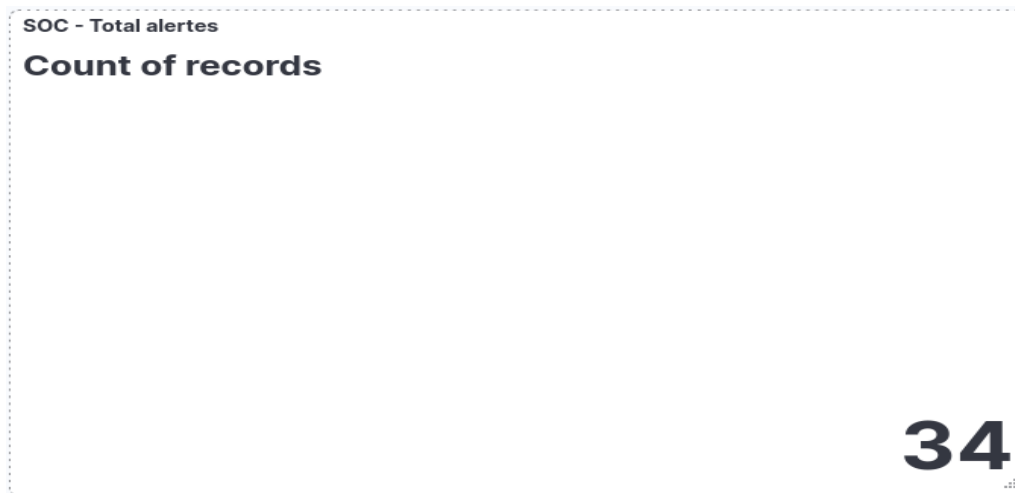


Figure 7 KPI Kibana – Total des alertes (34)

Le compteur global affiché dans le panneau "SOC – Total alertes" indique 34 enregistrements sur la durée de l'exercice. Avant l'attaque, ce même compteur affichait N/A (aucune activité). Le passage de zéro à 34 alertes en quelques minutes représente un signal d'alarme clair qu'un analyste SOC ne peut pas ignorer.

Interprétation analyste : Un volume de 34 alertes concentré sur une fenêtre de moins de 15 minutes (12:19–12:30) est totalement incohérent avec un trafic réseau normal dans un lab en état de repos. Dans un environnement réel, ce type de pic déclencherait immédiatement une escalade vers un analyste de niveau 2 et l'ouverture d'un ticket d'incident avec une priorité élevée. La corrélation directe entre le lancement de Hydra et l'apparition des alertes confirme que le système de détection fonctionne correctement de bout en bout.

4.2. Visualisation 2 : Évolution temporelle des alertes

Observation : pic concentré entre 12h19 et 12h30 le 06 mai 2026



Figure 8 Graphique temporel – Pic d'alertes concentré entre 12h19 et 12h30

Le graphique temporel "Suricata – Alertes dans le temps" montre une ligne plate à zéro avant 12h19, puis un pic brutal et isolé au moment du lancement des attaques Hydra. Le pic atteint 11 à 12 alertes par intervalle de 30 secondes au moment de l'attaque SSH, suivi d'un second pic plus court lors de l'attaque HTTP. Avant et après ces deux fenêtres : activité nulle.

Ce comportement en deux temps un premier pic SSH suivi d'un second pic HTTP est caractéristique d'une attaque par force brute séquentielle menée avec Hydra, et confirme la corrélation entre les actions de l'attaquant et les alertes générées.

4.3. Visualisation 3 : Top signatures déclenchées

Données Kibana observées :

SOC - Top signatures	
Top 10 values of alert.signature.keyword	Count of records
Tentative connexion SSH - Brute Force potentiel	15
HTTP POST Login - Brute Force HTTP potentiel	5
ET INFO HTTP POST contains pass= in cleartext	4
ET SCAN Possible Nmap User-Agent Observed	4
Tentative authentification HTTP detectee	4
ICMP Ping detecte	2

Figure 9 Top signatures déclenchées

Interprétation : La signature SSH Brute Force domine avec 15 alertes, ce qui reflète directement les nombreuses tentatives de connexion envoyées par Hydra sur le port 22.

La signature "ET INFO HTTP POST contains pass= in cleartext" est particulièrement intéressante : elle indique que les mots de passe sont transmis en clair dans le corps des requêtes HTTP, ce qui constitue une vulnérabilité supplémentaire. L'alerte "ET SCAN Possible Nmap User-Agent Observed" vient quant à elle de la reconnaissance préalable effectuée avant l'attaque. L'ensemble de ces signatures montre que le système de détection a correctement couvert tous les vecteurs utilisés dans cet exercice.

4.4. Visualisation 4 : Top Sources IP (Pie chart)

Données Kibana observées :

Tableau 2 Répartition des alertes par IP source

IP Source	Part
192.168.10.10 (Kali – Attaquant)	90.91%
192.168.10.30 (ELK Stack)	9.09%

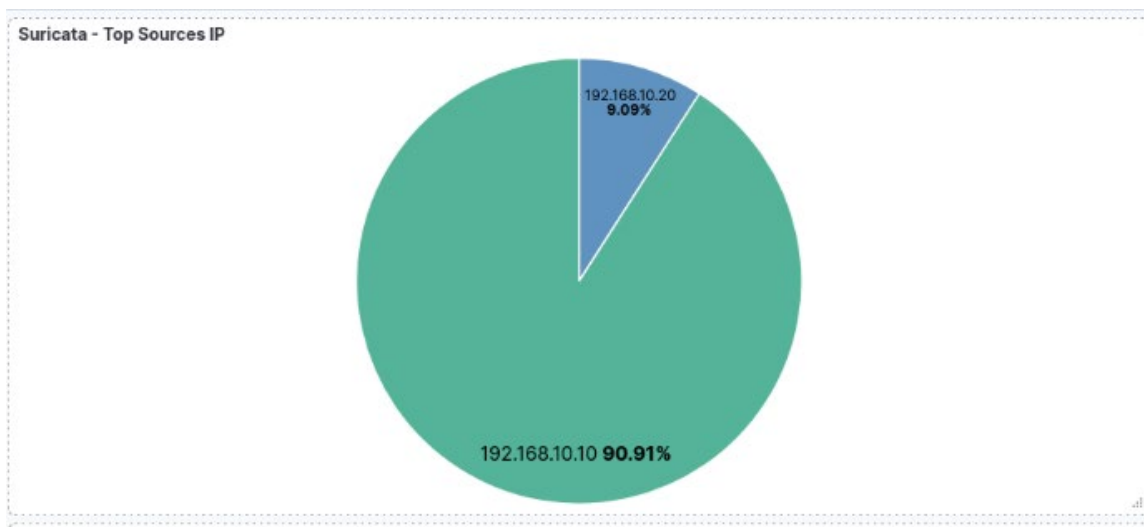


Figure 10 Diagramme circulaire – Top sources IP

L'origine de l'activité est sans ambiguïté : la machine 192.168.10.10 est responsable de 90,91% des alertes. Les 9,09% restants proviennent du trafic réseau normal du lab. Ce diagramme est l'un des éléments les plus utiles dans un SOC, car il permet d'identifier l'adresse IP de l'attaquant en un seul coup d'œil, sans avoir à analyser les logs ligne par ligne.

Ce comportement est attendu et confirme que la règle d'attribution de source fonctionne correctement dans Kibana.

4.5. Visualisation 5 : Types d'attaques (bar chart)

La visualisation "Suricata - Types d'attaques" reproduit visuellement la même distribution que la table des signatures, avec en tête la tentative de connexion SSH Brute Force (15 alertes), suivie des alertes HTTP POST (5 alertes), de la détection des credentials en clair (4 alertes) et de la tentative d'authentification HTTP (4 alertes).

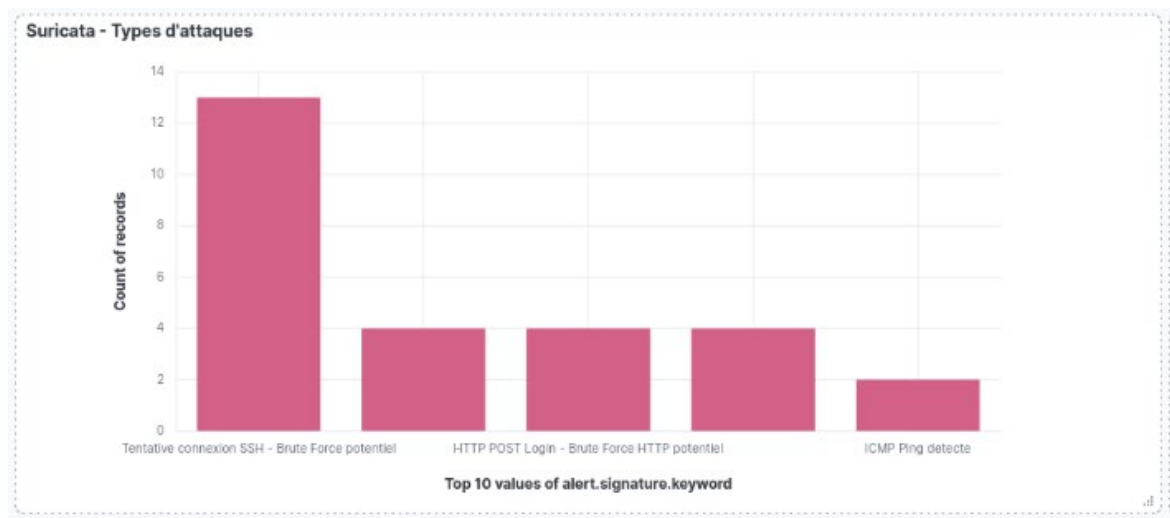


Figure 11 Histogramme – Types d'attaques détectées

Cette représentation en histogramme permet de voir d'un seul regard que l'attaque SSH a été plus intensive en volume que l'attaque HTTP, ce qui s'explique par le nombre plus élevé de tentatives SSH (56 tentatives) par rapport aux tentatives HTTP (4 tentatives avant succès).

Visualisation 6 : Top ports ciblés

Données Kibana observées :

Tableau 3 Top des ports ciblés

Port	Count approximatif
22 (SSH)	11 (dominant)
80 (HTTP)	11 (dominant)

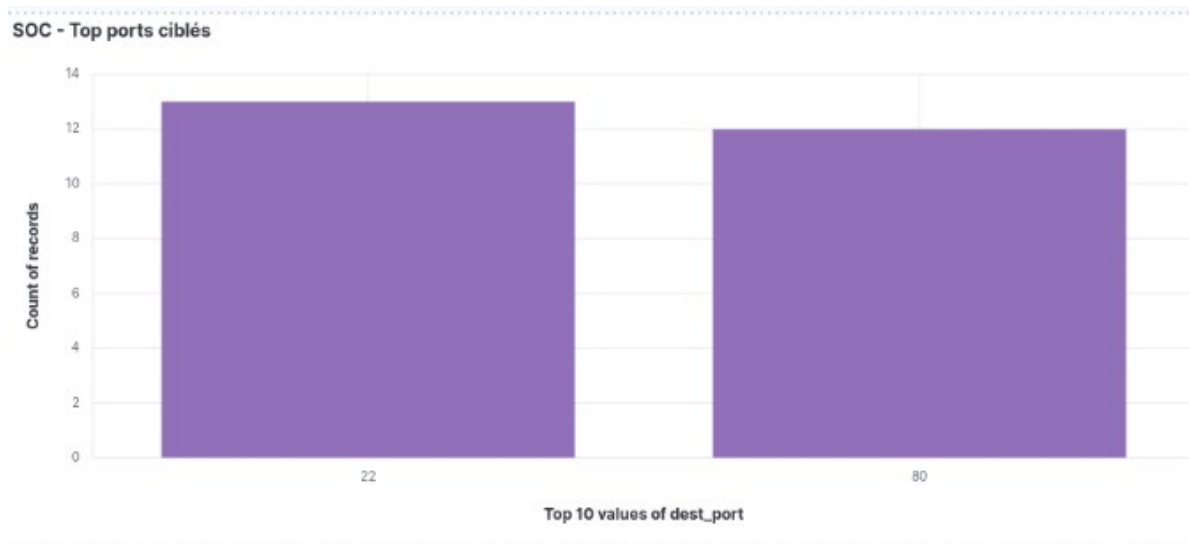


Figure 12 Top ports ciblés

Interprétation : Les deux ports ciblés — 22 (SSH) et 80 (HTTP) — apparaissent à volumes équivalents dans le dashboard, ce qui confirme que les deux phases de l'attaque ont bien été exécutées et détectées. Dans un contexte réel, la présence simultanée de deux services attaqués en séquence est un indicateur fort d'une attaque coordonnée et méthodique, et non d'une activité accidentelle. Un analyste SOC devrait corrélérer ces deux signaux ensemble plutôt que de les traiter comme des événements séparés.

5. Analyse des logs Suricata – fast.log

Le fichier fast.log consulté via `tail -f /var/log/suricata/fast.log` confirme les alertes en temps réel avec le détail suivant :

```
(root@kali)-[~]
# tail -f /var/log/suricata/fast.log
05/06/2026-12:27:08.760655  [**] [1:1000001:1] ICMP Ping detecte [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.10.20:8 → 192.168.10.10:0
05/06/2026-12:27:08.760710  [**] [1:1000001:1] ICMP Ping detecte [**] [Classification: (null)] [Priority: 3] {ICMP} 192.168.10.10:0 → 192.168.10.20:0
05/06/2026-12:27:26.146455  [**] [1:1000002:2] Tentative connexion SSH - Brut e Force potentiel [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:49406 → 192.168.10.20:22
05/06/2026-12:27:26.512749  [**] [1:1000002:2] Tentative connexion SSH - Brut e Force potentiel [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:49418 → 192.168.10.20:22
05/06/2026-12:27:26.512998  [**] [1:1000002:2] Tentative connexion SSH - Brut e Force potentiel [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:49432 → 192.168.10.20:22
05/06/2026-12:27:26.513690  [**] [1:1000002:2] Tentative connexion SSH - Brut e Force potentiel [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:49448 → 192.168.10.20:22
05/06/2026-12:27:26.514913  [**] [1:1000002:2] Tentative connexion SSH - Brut e Force potentiel [**] [Classification: (null)] [Priority: 3] {TCP} 192.168.10.10:49454 → 192.168.10.20:22
```

Figure 13 Extrait du fichier fast.log de Suricata

Analyse des logs :

- Cohérence temporelle : Les timestamps des alertes correspondent exactement aux fenêtres d'exécution des attaques Hydra (12:27 pour l'attaque SSH, 12:29 pour l'attaque HTTP). Cette corrélation directe entre les actions de l'attaquant et les alertes générées est la preuve que le système de détection fonctionne en temps réel.
- Identification des règles custom : Les SIDs 1:1000001, 1:1000002, 1:1000004 correspondent aux règles définies manuellement dans le fichier local.rules (tout SID supérieur à 1000000 est une règle locale). Cela prouve que les règles personnalisées sont bien chargées et actives dans Suricata au moment de l'exercice.
- Caractéristique de la force brute visible dans les logs : À 12:27:26, on observe plusieurs alertes SID 1000002 générées à la milliseconde près depuis la même IP source (192.168.10.10) mais depuis des ports sources différents (49406, 49418, 49432, 49448...). Ce comportement est la signature typique d'un outil de force brute multi-thread : Hydra ouvre plusieurs connexions TCP parallèles simultanément (-t 4), ce qui génère des ports sources éphémères différents pour chaque thread, tous visibles dans les logs.

- Traçabilité complète : Chaque entrée du fast.log contient l'IP source, l'IP destination, le port source éphémère et le port destination ciblé. Ces informations sont suffisantes pour une corrélation forensique complète et une reconstruction précise de la chronologie de l'attaque.

6. Résumé des indicateurs de compromission (IoC) :

Tableau 4 Indicateurs de compromission (IoC)

Type	Valeur	Contexte
IP Source	192.168.10.10	Machine Kali – origine de 90.91% des alertes
IP Cible	192.168.10.20	Ubuntu Server – cible unique
Port ciblé 1	22/tcp (SSH)	Service compromis — credentials user:test trouvés
Port ciblé 2	80/tcp (HTTP)	Service compromis — credentials admin:admin123 trouvés
Credentials SSH compromis	user : test	Trouvés à la tentative n°56/80 en ~40 secondes
Credentials HTTP compromis	admin : admin123	Trouvés à la tentative n°4/18 en moins d'1 seconde
Outil d'attaque	Hydra v9.5 (THC-Hydra)	Identifiable via les logs de connexion SSH
Service exposé 1	OpenSSH 8.9p1 Ubuntu	Version identifiée lors de la reconnaissance Nmap préalable
Service exposé 2	Apache HTTP / PHP	Formulaire login.php sans protection contre la force brute
Phase Cyber Kill Chain	Phase 4 – Exploitation	Accès aux systèmes via credentials compromis par force brute

7. Recommandations de remédiation :

Immédiat (0-24h)

Bloquer l'IP 192.168.10.10 au niveau du pare-feu en attendant l'investigation complète de la machine source (dans un contexte réel).

Désactiver immédiatement l'authentification par mot de passe SSH sur la machine cible et basculer exclusivement sur l'authentification par clé SSH (PasswordAuthentication no dans /etc/ssh/sshd_config). Une clé SSH est mathématiquement impossible à trouver par force brute contrairement à un mot de passe.

Changer les credentials compromis (user:test et admin:admin123) et appliquer une politique de mots de passe forte : minimum 12 caractères, mélange de majuscules, chiffres et caractères spéciaux, interdiction des mots de passe figurant dans des listes connues.

Court terme (1-7 jours)

Installer et configurer Fail2Ban sur la machine cible. Fail2Ban est un outil de sécurité qui surveille les fichiers de logs et bloque automatiquement via le pare-feu toute adresse IP ayant effectué un nombre configurable de tentatives d'authentification échouées (par exemple, blocage après 5 échecs consécutifs pendant 10 minutes). Cette mesure aurait stoppé l'attaque Hydra dès les premières tentatives.

Ajouter un système de rate limiting HTTP sur le formulaire de connexion PHP : limiter le nombre de requêtes POST acceptées depuis une même IP par unité de temps (par exemple, 5 tentatives maximum par minute). Sans cette limitation, n'importe quel outil peut soumettre des centaines de tentatives par seconde.

Passer Suricata en mode IPS (drop au lieu de alert) pour les règles de force brute validées, afin de bloquer automatiquement le trafic malveillant en temps réel plutôt que de simplement l'alerter.

Configurer des alertes Kibana (Alerting) pour notifier automatiquement le SOC par e-mail ou ticket dès qu'un seuil d'alertes est dépassé (par exemple : plus de 10 alertes SSH en moins d'1 minute depuis la même IP).

Moyen terme (1-4 semaines)

Mettre en place une authentification multi-facteur (MFA) sur tous les services exposés, en particulier SSH et les interfaces web d'administration. Même si un attaquant obtient un mot de passe par force brute, le MFA l'empêche de se connecter sans le second facteur.

Segmenter le réseau avec des VLANs et un pare-feu inter-zone pour isoler la machine attaquant de la machine cible, rendant toute tentative de connexion directe impossible sans passer par un point de contrôle.

Enrichir les règles Suricata en ajoutant des seuils (thresholds) : au lieu d'alerter pour chaque tentative de connexion SSH individuelle, configurer une alerte unique déclenchée uniquement lorsque le nombre de connexions depuis une même IP dépasse un seuil défini (par exemple : 10 connexions en 5 secondes). Cela réduit le volume d'alertes tout en maintenant la pertinence de la détection.

Conclusion :

L'exercice d'attaque par force brute mené le 06 mai 2026 a permis de valider l'efficacité de la chaîne de détection Suricata → Logstash → Elasticsearch → Kibana face à une attaque réelle menée avec l'outil Hydra.

Les règles personnalisées local.rules ont correctement déclenché des alertes sur les tentatives de connexion SSH et HTTP en temps réel. Le SIEM Kibana a correctement récupéré, indexé et affiché les alertes. La visualisation du dashboard SOC permet une lecture immédiate de la situation : volume d'alertes, timeline, attribution de source, nature de l'attaque et services ciblés.

Les deux accès ont été compromis avec succès, ce qui confirme que des mots de passe faibles (test, admin123) combinés à une absence de protection contre la force brute (pas de Fail2Ban, pas de rate limiting, pas de MFA) constituent un risque critique même pour un système protégé par un IDS.